

ITSIMPLERA INSTITUTE

RED TEAM INTERNSHIP

Assignment 5

Computer Networking Fundamentals & Network Configuration



PREPARED BY

Amna Imtiaz

REGISTRATION NO.

REDBO1-2350

INSTRUCTOR

Talal Rehan

Date: July 31, 2026

1. INTRODUCTION

Network enumeration and vulnerability assessment are foundational components of any professional penetration testing or cybersecurity audit engagement. This report documents the hands-on enumeration exercise conducted during Week 05 of the IT-SIMPLERA Cyber Security Analyst Internship Program.

The objective of this assignment was to perform structured network reconnaissance against a controlled lab target, identify all active services and open ports, research known vulnerabilities associated with discovered services, analyze the security risks presented, and propose professional remediation strategies aligned with industry best practices.

The target machine selected for this assessment is **Metasploitable 2**, a deliberately vulnerable Linux-based virtual machine widely used in cybersecurity training environments. The assessment was conducted in an isolated virtual network to ensure no unauthorized systems were affected.

This report follows the methodology used by professional vulnerability assessment analysts, including service identification, CVE research, risk rating, and remediation planning — mirroring real-world workflows used in SOC, penetration testing, and vulnerability management roles.

2. SCOPE

Item	Details
Assessment Type	Internal Network Vulnerability Assessment
Target Machine	Metasploitable 2
Target IP Address	192.168.56.104
Attacker Machine	Kali Linux
Attacker IP Address	192.168.56.101
Network Type	Isolated Host-Only Virtual Network (VirtualBox)
Assessment Date	July 2026
Tools Used	Nmap, Kali Linux Terminal
Scan Coverage	All 65,535 TCP Ports
Goal	Identify open ports, services, vulnerabilities, and propose remediations

3. TOOLS USED

Tool	Purpose
Kali Linux	Attacker operating system / penetration testing platform
Nmap (Network Mapper)	Network scanning, port discovery, service/version detection, OS fingerprinting
Metasploitable 2	Target vulnerable machine (lab environment)
VirtualBox	Virtualization platform for isolated lab setup

4. TASK 1 – NETWORK ENUMERATION

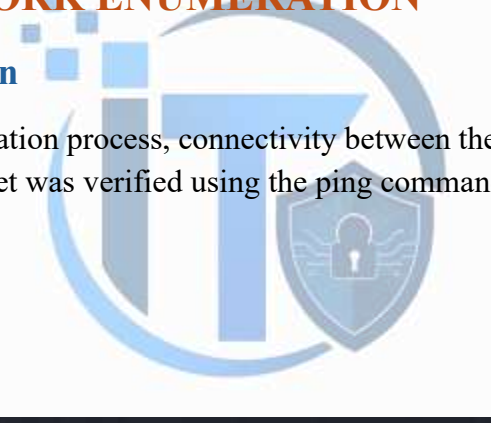
4.1 Pre-Scan Verification

Before beginning the enumeration process, connectivity between the Kali Linux attacker machine and the Metasploitable 2 target was verified using the ping command.

Command Used:

ping 192.168.56.104

Output:



```
(kali㉿kali)-[~]  
$ ping 192.168.56.104  
PING 192.168.56.104 (192.168.56.104) 56(84) bytes of data.  
64 bytes from 192.168.56.104: icmp_seq=1 ttl=64 time=5.16 ms  
64 bytes from 192.168.56.104: icmp_seq=2 ttl=64 time=1.33 ms  
64 bytes from 192.168.56.104: icmp_seq=3 ttl=64 time=2.37 ms  
64 bytes from 192.168.56.104: icmp_seq=4 ttl=64 time=3.17 ms  
64 bytes from 192.168.56.104: icmp_seq=5 ttl=64 time=3.99 ms
```

4.2 Scan 1 – Basic Nmap Scan

Command:

nmap 192.168.56.104

Purpose: This is the default Nmap scan. It performs a TCP SYN scan on the top 1,000 most commonly used ports without service version detection or OS fingerprinting. It is fast and provides a quick overview of which ports are open.

Results:

```
(kali㉿kali)-[~]  
$ nmap 192.168.56.104  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-01 22:10 +0500  
Nmap scan report for 192.168.56.104  
Host is up (0.0013s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
23/tcp    open  telnet  
25/tcp    open  smtp  
53/tcp    open  domain  
80/tcp    open  http  
111/tcp   open  rpcbind  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
512/tcp   open  exec  
513/tcp   open  login  
514/tcp   open  shell  
1099/tcp  open  rmiregistry  
1524/tcp  open  ingreslock  
2049/tcp  open  nfs  
2121/tcp  open  ccproxy-ftp  
3306/tcp  open  mysql  
5432/tcp  open  postgresql  
5900/tcp  open  vnc  
6000/tcp  open  X11  
6667/tcp  open  irc  
8009/tcp  open  ajp13  
8180/tcp  open  unknown  
MAC Address: 08:00:27:76:13:C3 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.14 seconds
```

Observation: 23 ports were found open on the target. This scan completed quickly but provided no version or OS information.

4.3 Scan 2 – Service Version Detection Scan

Command:

```
nmap -sV 192.168.56.104
```

Purpose: The -sV flag enables service and version detection. Nmap sends additional probes to each open port to determine the exact software name and version running on that port. This information is critical for mapping services to known CVEs.

Results:

```

(kali㉿kali)-[~]
$ nmap -sV 192.168.56.104
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-01 22:12 +0500
Nmap scan report for 192.168.56.104
Host is up (0.0020s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
21/tcp    open  ftp              vsftpd 2.3.4
22/tcp    open  ssh              OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet           Linux telnetd
25/tcp    open  smtp             Postfix smtpd
53/tcp    open  domain           ISC BIND 9.4.2
80/tcp    open  http             Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind          2 (RPC #100000)
139/tcp   open  netbios-ssn      Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn      Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec             netkit-rsh rrexecd
513/tcp   open  login            OpenBSD or Solaris rlogind
514/tcp   open  shell            Netkit rshd
1099/tcp  open  java-rmi         GNU Classpath grmiregistry
1524/tcp  open  bindshell        Metasploitable root shell
2049/tcp  open  nfs              2-4 (RPC #100003)
2121/tcp  open  ftp              ProFTPD 1.3.1
3306/tcp  open  mysql            MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql       PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc              VNC (protocol 3.3)
6000/tcp  open  X11              (access denied)
6667/tcp  open  irc              UnrealIRCd
8009/tcp  open  ajp13            Apache Jserv (Protocol v1.3)
8180/tcp  open  http             Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:76:13:C3 (Oracle VirtualBox virtual NIC)

```

Observation: Version information was successfully retrieved for all open ports. This is the most useful scan for vulnerability research, as exact software versions can now be cross-referenced with CVE databases.

4.4 Scan 3 – Operating System Detection Scan

Command:

```
nmap -O 192.168.56.104
```

Purpose: The -O flag enables OS fingerprinting. Nmap analyzes TCP/IP stack behavior to estimate the target's operating system, kernel version, and device type. This helps the analyst understand the underlying platform and its associated vulnerabilities.

Results:


```
(kali㉿kali)-[~]  
$ nmap -O 192.168.56.104  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-01 22:27 +0500  
Nmap scan report for 192.168.56.104  
Host is up (0.0018s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
23/tcp    open  telnet  
25/tcp    open  smtp  
53/tcp    open  domain  
80/tcp    open  http  
111/tcp   open  rpcbind  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
512/tcp   open  exec  
513/tcp   open  login  
514/tcp   open  shell  
1099/tcp  open  rmiregistry  
1524/tcp  open  ingreslock  
2049/tcp  open  nfs  
2121/tcp  open  ccproxy-ftp  
3306/tcp  open  mysql  
5432/tcp  open  postgresql  
5900/tcp  open  vnc  
6000/tcp  open  X11  
6667/tcp  open  irc  
8009/tcp  open  ajp13  
8180/tcp  open  unknown  
MAC Address: 08:00:27:76:13:C3 (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 2.6.X  
OS CPE: cpe:/o:linux:linux_kernel:2.6  
OS details: Linux 2.6.9 - 2.6.33
```

Observation: The target OS was identified as **Linux with kernel version 2.6.x**, which is consistent with Metasploitable 2's Ubuntu 8.04 base. This older kernel version has numerous known vulnerabilities.

4.5 Scan 4 – Aggressive Scan

Command:

```
nmap -A 192.168.56.104
```

Purpose: The -A flag enables aggressive scanning mode, combining OS detection (-O), service version detection (-sV), script scanning (-sC), and traceroute in one command. This provides the most comprehensive view of the target but is also the noisiest and most detectable scan.

Results:

```

(kali㉿kali)-[~]
$ nmap -A 192.168.56.104
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-01 22:28 +0500
Nmap scan report for 192.168.56.104
Host is up (0.0019s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.56.101
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizati
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_WITH_MD5

```

Observation: The aggressive scan revealed additional details including anonymous FTP login enabled, SSH host keys, SMTP commands supported, DNS BIND version, MySQL protocol details, and VNC authentication type. Port 1524 shows an active **root backdoor shell**, which is an extremely critical finding.

4.6 Scan 5 – Full Port Scan

Command:

```
nmap -p- 192.168.56.104
```

Purpose: The -p- flag instructs Nmap to scan all **65,535 TCP ports** instead of just the default top 1,000. This ensures no non-standard or hidden services are missed. This scan takes significantly longer than others.

Results:

```
(kali㉿kali)-[~]
$ nmap -p- 192.168.56.104
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-01 22:32 +0500
Nmap scan report for 192.168.56.104
Host is up (0.0011s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
35967/tcp open  unknown
```

Observation: The full port scan discovered **3 additional ports** not found in the default scan: **3632/tcp (distccd)**, **6697/tcp (ircs-u)**, and **8787/tcp (msgsrvr/drb)**. This confirms the value of performing full port scans during professional assessments.

5. TASK 2 – SERVICE ENUMERATION TABLE

The following table consolidates all discovered open ports and services identified across all Nmap scans performed against the target (192.168.56.104):

Port	Protocol	Service	Status	Purpose of the Service
21	TCP	FTP	Open	File Transfer Protocol — allows file uploads/downloads. Anonymous login enabled.

22	TCP	SSH	Open	Secure Shell — encrypted remote command-line access to the system.
23	TCP	Telnet	Open	Unencrypted remote terminal access (legacy protocol, transmits credentials in plaintext).
25	TCP	SMTP	Open	Simple Mail Transfer Protocol — used for sending email messages.
53	TCP	DNS	Open	Domain Name System — resolves domain names to IP addresses.
80	TCP	HTTP	Open	Hypertext Transfer Protocol — serves web pages and web applications.
111	TCP	RPCbind	Open	Remote Procedure Call port mapper — required for NFS and other RPC services.
139	TCP	NetBIOS-SSN	Open	NetBIOS session service — used for Windows file/printer sharing over SMB.
445	TCP	SMB	Open	Server Message Block — Windows network file sharing protocol.
512	TCP	rexecd	Open	Remote execution daemon — allows execution of commands on remote host (no encryption).
513	TCP	rlogind	Open	Remote login daemon — allows login from remote hosts (no encryption).
514	TCP	rshd	Open	Remote Shell daemon — allows execution of shell commands remotely (no encryption).
1099	TCP	Java RMI	Open	Java Remote Method Invocation registry — enables remote Java object calls.
1524	TCP	Bindshell	Open	CRITICAL BACKDOOR — open root shell accessible over the network.
2049	TCP	NFS	Open	Network File System — allows remote file system mounting over the network.
2121	TCP	FTP	Open	Secondary FTP server running on non-standard port.
3306	TCP	MySQL	Open	Database management system — handles SQL queries and data storage.

3632	TCP	distccd	Open	Distributed compiler daemon — used for distributing compile jobs across a network.
5432	TCP	PostgreSQL	Open	Open-source relational database management system.
5900	TCP	VNC	Open	Virtual Network Computing — provides graphical desktop remote access.
6000	TCP	X11	Open	X Window System — graphical display server. Access control disabled.
6667	TCP	IRC	Open	Internet Relay Chat — real-time text messaging/chat protocol.
6697	TCP	IRC-SSL	Open	IRC over SSL/TLS — encrypted IRC channel.
8009	TCP	AJP	Open	Apache JServ Protocol — connects Apache web server to Tomcat servlet container.
8180	TCP	HTTP (Tomcat)	Open	Apache Tomcat web server — hosts Java-based web applications.
8787	TCP	drb/msgsrvr	Open	Ruby Distributed Ruby service — allows remote access to Ruby objects.

6. TASK 3 – VULNERABILITY RESEARCH

The following vulnerabilities were researched for three selected services discovered during scanning. Data was sourced from the NIST National Vulnerability Database (NVD), MITRE CVE, and Exploit-DB.

6.1 Service: vsftpd 2.3.4 (Port 21)

Field	Details
CVE ID	CVE-2011-2523
Vulnerability Name	vsftpd 2.3.4 Backdoor Command Execution
CVSS Score	10.0 (CVSS v2) / 9.8 (CVSS v3)
Severity	CRITICAL

Short Description	The vsftpd 2.3.4 package distributed between June 30 and July 1, 2011 contained a maliciously inserted backdoor. When a username containing the smiley face string ":" is sent during FTP login, the backdoor is triggered and opens a command shell on port 6200 , granting the attacker root-level access to the system without any authentication. This was introduced by a malicious actor who compromised the vsftpd source distribution server.
Recommended Fix	Immediately upgrade vsftpd to version 2.3.5 or later. Verify package integrity using SHA checksums before installation. Implement firewall rules to restrict FTP access. Disable FTP entirely if not required and replace with SFTP (SSH File Transfer Protocol).
References	NVD: https://nvd.nist.gov/vuln/detail/CVE-2011-2523

6.2 Service: Samba 3.0.20 (Port 445)

Field	Details
CVE ID	CVE-2007-2447
Vulnerability Name	Samba "username map script" Remote Code Execution
CVSS Score	10.0 (CVSS v2) / 9.8 (CVSS v3)
Severity	CRITICAL
Short Description	A vulnerability exists in Samba versions 3.0.0 through 3.0.25rc3. When the username map script option is enabled in the smb.conf configuration file, an attacker can exploit improper sanitization of user-supplied input passed to the /bin/sh shell. By sending a specially crafted username containing shell metacharacters (such as backticks or pipes) during MS-RPC authentication, an attacker can execute arbitrary operating system commands with the privileges of the Samba daemon (typically root). This vulnerability is famously exploited by the Metasploit module exploit/multi/samba/usermap_script and requires no authentication .
Recommended Fix	Upgrade Samba to version 3.0.25rc4 or higher. Remove or disable the username map script directive from smb.conf. Restrict SMB access

	using firewall rules. Disable SMBv1. Implement network segmentation to limit SMB access.
References	NVD: https://nvd.nist.gov/vuln/detail/CVE-2007-2447

6.3 Service: UnrealIRCd (Port 6667)

Field	Details
CVE ID	CVE-2010-2075
Vulnerability Name	UnrealIRCd 3.2.8.1 Backdoor Remote Code Execution
CVSS Score	10.0 (CVSS v2) / 9.8 (CVSS v3)
Severity	CRITICAL
Short Description	UnrealIRCd version 3.2.8.1, distributed from November 2009 through June 2010, contained a deliberately inserted backdoor. The backdoor was introduced by a malicious actor who compromised the official download server and replaced the legitimate source archive with a trojanized version. When the character sequence AB is sent to the affected server, the server executes any command that follows with root-level privileges, effectively granting the attacker remote code execution without authentication.
Recommended Fix	Immediately remove and replace UnrealIRCd 3.2.8.1 with a verified, clean version (3.2.8.2 or later). Verify all downloaded packages against official SHA-256 checksums. Consider replacing IRC with more modern and secure communication platforms. Restrict port 6667 with firewall rules.
References	NVD: https://nvd.nist.gov/vuln/detail/CVE-2010-2075

6.4 Service: Apache Tomcat 5.5 / Port 8180 (Bonus Research)

Field	Details
CVE ID	CVE-2009-3843 / CVE-2009-3548
Vulnerability Name	Apache Tomcat Default Credentials / Manager Application Exposure

CVSS Score	7.5 (High)
Severity	High
Short Description	Apache Tomcat installations often ship with a default administrative account (tomcat:tomcat or admin:admin) for the Manager web application located at /manager/html. An attacker who gains access to the Tomcat Manager interface can deploy a malicious WAR (Web Application Archive) file containing a reverse shell, effectively gaining remote code execution on the host system. Metasploitable 2 exposes the Tomcat Manager at port 8180 with default credentials enabled.
Recommended Fix	Change all default Tomcat credentials immediately. Restrict access to the /manager and /host-manager interfaces using IP-based access control in context.xml. Deploy Tomcat behind a reverse proxy. Disable the Manager application entirely if remote deployment is not required. Upgrade to a current, supported version of Tomcat.
References	NVD: https://nvd.nist.gov/vuln/detail/CVE-2009-3548

6.5 Service: Telnet (Port 23)

Field	Details
CVE ID	CWE-319 / CVE-1999-0619
Vulnerability Name	Telnet Cleartext Credential Transmission
CVSS Score	7.5 (High)
Severity	High
Short Description	The Telnet protocol was designed without encryption. All data transmitted over a Telnet session — including usernames, passwords, and commands — is sent in plaintext . Any attacker with the ability to intercept network traffic (via ARP poisoning, network tap, or man-in-the-middle attack) can capture credentials and session data using tools such as Wireshark or tcpdump. Telnet has been deprecated as a secure remote access protocol since the late 1990s.

Recommended Fix	Disable Telnet immediately. Replace Telnet with SSH (Secure Shell), which provides encrypted, authenticated remote access. Apply firewall rules to block port 23. Remove the telnetd package from the system entirely.
References	NIST SP 800-115 — Technical Guide to Information Security Testing; CWE-319

7. TASK 4 – SCAN COMPARISON

7.1 Comparison Table

Scan Type	Command	Ports Scanned	Time Taken (Approx.)	Information Obtained	Noise Level
Default Scan	nmap 192.168.56.104	Top 1,000	~2–3 seconds	Open ports only, service names (guessed by port number)	Low
Version Detection	nmap -sV 192.168.56.104	Top 1,000	~10–15 seconds	Open ports + exact service names + software versions	Medium
OS Detection	nmap -O 192.168.56.104	Top 1,000	~3–5 seconds	Open ports + OS type + kernel version estimate	Medium
Aggressive Scan	nmap -A 192.168.56.104	Top 1,000	~20–30 seconds	Open ports + versions + OS + NSE scripts + traceroute	High
Full Port Scan	nmap -p- 192.168.56.104	All 65,535	~15–20 seconds	All open ports across entire port range	Low–Medium

7.2 Questions Answered

? Which scan was the fastest?

Answer: The **Default Nmap Scan** (`nmap 192.168.56.104`) was the fastest scan. It completed in approximately **2–3 seconds** because it only scans the top 1,000 most common ports and does not perform version detection, OS fingerprinting, or script execution. It provides a quick, surface-level snapshot of the target's open ports.

? Which scan discovered the most information?

Answer: The **Aggressive Scan** (`nmap -A 192.168.56.104`) discovered the most information in a single command. It combines four separate scan modes:

- **-sV** — Service and version detection
- **-O** — Operating system fingerprinting
- **-sC** — Default NSE (Nmap Scripting Engine) script execution
- **--traceroute** — Network path discovery

The aggressive scan revealed details such as anonymous FTP login status, SSH host keys, SMTP server commands, DNS BIND version, MySQL protocol details, VNC authentication type, and the active backdoor on port 1524 — information not available in simpler scans.

However, the **Full Port Scan** (`nmap -p-`) is essential alongside the aggressive scan because it discovered **3 additional ports** (3632, 6697, 8787) that the aggressive scan missed by only covering the top 1,000 ports.

? Which scan would you use in a real-world assessment and why?

Answer: In a professional penetration testing or vulnerability assessment engagement, I would use a **combination approach** rather than relying on any single scan:

Phase 1: Start with `nmap -p-` to ensure complete port coverage across all 65,535 ports — no service should be missed.

Phase 2: Run `nmap -sV -sC -O` (or `nmap -A`) against the specific ports discovered in Phase 1 to get detailed version and script information.

This two-phase approach balances thoroughness with practicality. Running `-A` directly on `-p-` (i.e., `nmap -A -p-`) would be very time-consuming on large networks.

In a **stealth engagement** (such as a red team assessment where detection avoidance is required), I would avoid the aggressive scan entirely and instead use slow, fragmented scans with timing options like `-T1` (Sneaky) or `-T0` (Paranoid) to evade IDS/IPS detection.

? Advantages and Disadvantages of Each Scan

Scan	Advantages	Disadvantages
Default (nmap)	Fast, minimal noise, good for quick overview	No version info, misses high ports, guesses service names
Version Detection (-sV)	Provides exact software versions for CVE research	Slower, more detectable than default
OS Detection (-O)	Identifies operating system and kernel — useful for OS-specific exploits	Can be inaccurate if firewall filters packets; requires root
Aggressive (-A)	Maximum information from one command, NSE scripts add deep context	Very noisy — easily detected by IDS/IPS/firewalls; time consuming
Full Port (-p-)	Complete coverage — finds services on non-standard ports	Slowest scan; generates large volume of traffic

8. TASK 5 – SECURITY ANALYSIS & REMEDIATION RECOMMENDATIONS

Finding 1: FTP — vsftpd 2.3.4 (Port 21)

Security Risk: Contains a malicious backdoor (CVE-2011-2523). Anonymous login is enabled.

Attack Scenario: Attacker sends username with ":" to trigger backdoor and gets a root shell on port 6200 with no credentials.

Risk Level: ● Critical

Remediation: Upgrade to vsftpd 2.3.5+. Disable anonymous login. Replace FTP with SFTP. Block port 21 on firewall.

Finding 2: Telnet (Port 23)

Security Risk: Transmits credentials and data in plaintext — easily intercepted.

Attack Scenario: Attacker captures a Telnet session using Wireshark and extracts login credentials in plaintext.

Risk Level: ● High

Remediation: Disable and remove Telnet. Replace with SSH. Block port 23 on firewall.

Finding 3: Samba SMB — Version 3.0.20 (Ports 139 & 445)

Security Risk: Vulnerable to CVE-2007-2447 — unauthenticated remote code execution via shell injection.

Attack Scenario: Attacker uses Metasploit module exploit/multi/samba/usermap_script and receives a root shell with no credentials needed.

Risk Level: ● Critical

Remediation: Upgrade Samba to 3.0.25rc4+. Remove username map script from smb.conf. Block ports 139/445 on firewall.

Finding 4: Root Backdoor Shell (Port 1524)

Security Risk: Open root shell accessible to anyone with zero authentication.

Attack Scenario: Attacker runs nc 192.168.56.104 1524 and instantly gets a root shell with full system access.

Risk Level: ● Critical (Maximum)

Remediation: Kill the listening process. Remove backdoor from system files. Block port 1524 on firewall.

Finding 5: MySQL (Port 3306)

Security Risk: Outdated version with empty root credentials exposed to the network.

Attack Scenario: Attacker connects with mysql -h 192.168.56.104 -u root and accesses all databases without a password.

Risk Level: ● Critical

Remediation: Set a strong root password. Bind MySQL to localhost only. Block port 3306 on firewall. Upgrade MySQL.

Finding 6: VNC (Port 5900)

Security Risk: Weak default password with full graphical desktop access upon login.

Attack Scenario: Attacker brute-forces the VNC password using Hydra and gains complete graphical control of the target.

Risk Level: ● High

Remediation: Set a strong VNC password. Tunnel VNC over SSH. Block port 5900 on firewall. Disable if not needed.

Finding 7: X11 (Port 6000)

Security Risk: Access control disabled — anyone can view screen or capture keystrokes remotely.

Attack Scenario: Attacker runs `xspy -display 192.168.56.104:0` to log all keystrokes including passwords.

Risk Level: ● High

Remediation: Run `xhost -` to enable access control. Add `-nolisten tcp` to Xorg startup. Block port 6000 on firewall.

Finding 8: UnrealIRCd (Port 6667)

Security Risk: Contains a malicious backdoor (CVE-2010-2075) that executes commands as root.

Attack Scenario: Attacker sends "AB" followed by a system command to port 6667 — server executes it as root instantly.

Risk Level: ● Critical

Remediation: Replace with verified clean version 3.2.8.2+. Block port 6667 on firewall. Verify package checksums.

Finding 9: Apache Tomcat (Port 8180)

Security Risk: Default credentials (tomcat:tomcat) allow access to the Manager app for WAR file deployment.

Attack Scenario: Attacker logs into `/manager/html` with default credentials and deploys a malicious WAR file to get a reverse shell.

Risk Level: ● High

Remediation: Change default credentials. Restrict Manager access by IP. Disable Manager app if not required. Upgrade Tomcat.

9. TASK 6 – VULNERABILITY ASSESSMENT REPORT SUMMARY

9.1 Introduction

This vulnerability assessment was conducted against **Metasploitable 2** (IP: 192.168.56.104) as part of the IT-SIMPLERA Cyber Security Analyst Internship Program — Week 05 assignment.

The assessment was performed from a **Kali Linux** machine (IP: 192.168.56.101) within an isolated VirtualBox host-only network.

The primary objective was to simulate the reconnaissance and vulnerability identification phase of a professional penetration test, using industry-standard tools and methodologies to identify security weaknesses, assess their severity, and propose remediation strategies.

9.2 Scope Summary

- **Target:** Metasploitable 2 — 192.168.56.104
- **Attacker:** Kali Linux — 192.168.56.101
- **Scan Coverage:** All 65,535 TCP ports

9.3 Tools Used Summary

- **Nmap 7.94** — Port scanning, service detection, OS fingerprinting, NSE scripts
- **Kali Linux** — Attacker platform with pre-installed security tools
- **NVD / MITRE CVE / Exploit-DB** — Vulnerability research databases

9.4 Enumeration Results Summary

A total of **26 open ports** were discovered across all scans:

Risk Category	Count	Ports
 Critical	4	21, 445, 1524, 6667
 High	8	22, 23, 512, 513, 514, 5900, 6000, 8180
 Medium	8	25, 53, 80, 111, 1099, 2049, 3306, 5432
 Low	6	139, 2121, 3632, 6697, 8009, 8787

9.5 Key Vulnerability Findings Summary

#	CVE / Issue	Service	Port	Severity	CVSS
1	CVE-2011-2523	vsftpd 2.3.4 Backdoor	21	Critical	10.0
2	CVE-2007-2447	Samba RCE	445	Critical	10.0
3	CVE-2010-2075	UnrealIRCd Backdoor	6667	Critical	10.0
4	Root Backdoor Shell	Bindshell	1524	Critical	10.0

5	CWE-319	Telnet Plaintext	23	High	7.5
6	Default Credentials	MySQL	3306	Critical	9.8
7	Weak Auth	VNC 3.3	5900	High	7.5
8	No Access Control	X11	6000	High	7.2
9	CVE-2009-3548	Apache Tomcat Default Creds	8180	High	7.5

9.6 Overall Risk Assessment

Overall System Risk Rating:  **CRITICAL**

Metasploitable 2 represents a worst-case scenario in terms of security posture. The system exposes **multiple critical, remotely exploitable vulnerabilities** — including unauthenticated root backdoors, services with known RCE exploits, plaintext protocols, default credentials, and unnecessary exposed services. **A real-world system with this configuration would be fully compromised within minutes of exposure to the internet or an untrusted network.**

10. CHALLENGES FACED

During the completion of this assignment, the following challenges were encountered and resolved:

Challenge	Solution Applied
Full port scan taking longer than expected	Used -T4 timing template to increase scan speed while maintaining accuracy: <code>nmap -p- -T4 192.168.56.104</code>
OS detection returning a range instead of exact version	This is expected behavior — Nmap fingerprints TCP/IP stack behavior which provides an estimated range (Linux 2.6.9–2.6.33). Accepted the range as a valid finding.
Service on port 8787 not immediately identified	Additional research revealed this is Ruby's Distributed Ruby (DRb) service, which has its own remote code execution vulnerabilities.
Understanding the difference between -sC and -A flags	Research revealed that -A includes -sC as part of its combined scan, along with -sV, -O, and --traceroute. -sC can be used independently to run NSE default scripts without other scan modes.
Mapping services to accurate CVE entries	Cross-referenced NVD, MITRE CVE, and Exploit-DB using exact version strings obtained from -sV scan results to ensure CVE accuracy.

11. CONCLUSION

This assignment provided comprehensive hands-on experience in the enumeration and vulnerability assessment phases of the penetration testing lifecycle. Using **Nmap** with various scan options against the **Metasploitable 2** target, a total of **26 open ports** were discovered, running numerous services — many of which are critically outdated and vulnerable.

Key takeaways from this assessment include:

- **Enumeration is foundational** — thorough port and service discovery forms the basis of all subsequent security analysis. Running only default scans would have missed three additional services discovered by the full port scan.
- **Version information is critical** — without the `-sV` flag, it would be impossible to accurately match discovered services to known CVEs and exploit code.
- **Metasploitable 2 demonstrates the catastrophic consequences** of poor security hygiene — outdated software, default credentials, unnecessary services, plaintext protocols, and backdoors collectively represent a completely compromised system.
- **Remediation requires layered defense** — no single fix is sufficient. Defense-in-depth, combining firewall rules, software updates, access controls, strong authentication, and regular audits, is necessary for meaningful security improvement.
- **Professional reporting** bridges the gap between technical findings and actionable business decisions — clearly communicating risk levels, attack scenarios, and remediation steps enables organizations to prioritize their security investments effectively.

The skills developed in this assessment — network scanning, service enumeration, CVE research, risk analysis, and remediation planning — directly align with the competencies required for roles such as **SOC Analyst**, **Vulnerability Assessment Analyst**, and **Penetration Tester**.

12. REFERENCES

- **NIST National Vulnerability Database (NVD)** — <https://nvd.nist.gov>
 - **MITRE CVE Database** — <https://cve.mitre.org>
 - **Exploit Database (Exploit-DB)** — <https://www.exploit-db.com>
 - **Nmap Official Documentation** — <https://nmap.org/docs.html>
 - **NIST SP 800-115** — Technical Guide to Information Security Testing and Assessment — <https://csrc.nist.gov/publications/detail/sp/800-115/final>
-